

INFORME DE CIBERSEGURIDAD

Plan de Respuesta a Incidentes

Caso de Estudio: TechCo bajo Ataque de Ransomware

Basado en el Marco de Ciberseguridad NIST CSF 2.0

IDENTIFICAR	PROTEGER	DETECTAR	RESPONDER & RECUPERAR
-------------	----------	----------	-----------------------

Resumen Ejecutivo

TechCo, empresa proveedora de servicios en la nube, fue victima de un ataque de ransomware originado mediante una campana de phishing dirigida a sus empleados. El incidente comprometio activos criticos incluyendo el servidor de archivos, la base de datos de clientes y los sistemas de respaldo internos, resultando en el cifrado total de la informacion y una exigencia de rescate de 50 Bitcoins (mas de USD 1,000,000).

El presente informe analiza el incidente bajo las cinco funciones del Marco de Ciberseguridad NIST (CSF 2.0): Identificar, Proteger, Detectar, Responder y Recuperar, con el objetivo de establecer un plan de accion formal que prevenga incidentes similares y reduzca el impacto de futuros ataques.

Hallazgos Criticos del Incidente

- 1. Ausencia de segmentacion de red: los backups residian en la misma red comprometida.
- 2. Sin monitoreo en tiempo real ni sistema de alerta temprana.
- 3. Capacitacion insuficiente del personal frente a ataques de ingenieria social.
- 4. Inexistencia de un plan formal de respuesta a incidentes previo al ataque.

01

IDENTIFICAR

Funcion 1 del Marco NIST CSF 2.0 — Gestion de Activos y Evaluacion de Riesgos

1.1 Activos Criticos Afectados

A continuacion se identifican los activos clave de TechCo que fueron comprometidos o que representan vectores de riesgo para las operaciones de la empresa:

Activo	Descripcion e Impacto
Servidor de Archivos	Almacena documentos operativos y datos esenciales para el funcionamiento diario. Impacto: CRITICO. El cifrado de este activo paralizo por completo las operaciones internas.
Base de Datos de Clientes	Contiene informacion personal y financiera sensible de los clientes. Impacto: CRITICO. La exposicion o perdida de estos datos puede derivar en sanciones regulatorias y perdida de confianza.
Sistemas de Backup Internos	Mecanismo de recuperacion ante desastres. Impacto: CRITICO. Al estar en la misma red, fueron cifrados junto con los datos de produccion, eliminando la via de recuperacion.
Infraestructura de Red	Conectividad interna entre servidores, estaciones de trabajo y servicios en la nube. Impacto: ALTO. La ausencia de segmentacion facilito la propagacion lateral del ransomware.
Estaciones de Trabajo	Equipos de los empleados, incluyendo el del empleado que recibio el phishing. Impacto: ALTO. Vector inicial del ataque y punto de entrada a la red corporativa.
Sistemas de Correo Electronico	Plataforma de comunicacion interna y externa. Impacto: ALTO. Utilizado como vector primario del ataque mediante phishing con adjuntos maliciosos.
Servicios en la Nube	Plataforma principal de negocio de TechCo. Impacto: MEDIO-ALTO. Dependiendo de la integracion con la red interna, podrian haber sido comprometidos secundariamente.

1.2 Vulnerabilidades que Facilitaron el Ataque

El analisis forense del incidente revela las siguientes vulnerabilidades estructurales:

- Falta de segmentacion de red (VLAN): la red plana permitio la propagacion irrestricta del malware desde el endpoint del empleado hasta servidores criticos y backups.
- Backups en la misma red logica que los sistemas de produccion: incumplimiento de la regla 3-2-1 de respaldo (3 copias, 2 medios distintos, 1 fuera de sitio).
- Ausencia de filtros avanzados de correo electronico (anti-phishing, sandboxing de adjuntos): el correo malicioso no fue interceptado.
- Carencia de capacitacion en concientizacion de seguridad: el empleado no identifico los indicadores de phishing en el correo recibido.
- Privilegios excesivos: la cuenta del empleado tenia acceso a recursos de red mas alla de lo necesario para su rol (violacion del principio de minimo privilegio).
- Sin sistemas de deteccion y respuesta en endpoints (EDR) capaces de bloquear la ejecucion del payload malicioso.
- Ausencia de MFA (Autenticacion Multifactor) en accesos a sistemas criticos.

Evaluacion de Riesgo Residual

Nivel de Riesgo Pre-Incidente: CRITICO. Las multiples vulnerabilidades encadenadas (phishing + red plana + backups expuestos + sin monitoreo) configuraron un escenario de maxima exposicion que facilito el exito del ataque y elimino las opciones de recuperacion inmediata.

02

PROTEGER

Funcion 2 del Marco NIST CSF 2.0 — Controles Preventivos y Políticas de Seguridad

2.1 Medidas Preventivas que Debieron Implementarse

A. Segmentacion de Red y Control de Acceso

- Implementar segmentacion de red mediante VLANs separadas para: servidores de produccion, sistemas de backup (aislados completamente), estaciones de trabajo de usuarios, y servicios de administracion.
- Aplicar firewalls internos (este-oeste) con politicas de denegacion por defecto entre segmentos.
- Implementar el modelo Zero Trust: ningun dispositivo ni usuario es confiable por defecto, incluso dentro de la red corporativa.
- Deshabilitar protocolos laterales innecesarios como SMB entre estaciones de trabajo.

B. Política de Respaldos (Regla 3-2-1-1)

- Mantener al menos 3 copias de los datos criticos.
- Almacenar en 2 medios diferentes (disco local + cinta o nube).
- 1 copia fuera del sitio fisico o en nube aislada (air-gapped).
- 1 copia inmutable (write-once) que el ransomware no pueda cifrar ni eliminar.
- Probar la restauracion de backups periodicamente (simulacros trimestrales).

C. Seguridad en Correo Electronico y Endpoints

- Implementar filtros anti-spam y anti-phishing con analisis de reputacion de dominios.
- Activar sandbox de adjuntos: todo archivo adjunto se ejecuta en un entorno virtual antes de entregarse al usuario.
- Desplegar solucion EDR (Endpoint Detection and Response) con capacidad de deteccion comportamental para bloquear cifrado masivo de archivos.
- Mantener parches y actualizaciones de seguridad al dia en todos los endpoints (gestion de parches automatizada).

D. Gestion de Identidades y Accesos (IAM)

- Implementar MFA (Autenticacion Multifactor) obligatoria para todos los sistemas criticos y accesos administrativos.
- Aplicar el principio de minimo privilegio: cada usuario y servicio accede solo a lo estrictamente necesario para su funcion.
- Revisar y auditar permisos periodicamente (semestral).
- Implementar PAM (Privileged Access Management) para cuentas administrativas.

E. Capacitacion y Concientizacion

- Programa de capacitacion obligatoria en ciberseguridad para todos los empleados, con actualizacion anual.
- Simulaciones de phishing periodicas (trimestrales) para medir y mejorar la deteccion del personal.
- Protocolo claro de reporte de correos sospechosos con un solo clic (boton 'Reportar Phishing').

Control de Seguridad	Prioridad / Beneficio
Segmentacion de Red	Alta
Backups Inmutables Offsite	Alta
MFA en sistemas criticos	Alta
Solucion EDR en endpoints	Alta
Capacitacion en phishing	Media
Sandbox de adjuntos de email	Media
Gestion de parches	Media

03**DETECTAR**

Funcion 3 del Marco NIST CSF 2.0 — Monitoreo Continuo y Alerta Temprana

3.1 Herramientas de Deteccion Recomendadas

A. SIEM (Security Information and Event Management)

Un SIEM centraliza y correlaciona logs de toda la infraestructura para identificar patrones anomalos.

Soluciones recomendadas: Splunk, IBM QRadar, Microsoft Sentinel.

- Correlacion de eventos de multiples fuentes en tiempo real.
- Alertas automaticas ante comportamientos sospechosos (e.j., cifrado masivo de archivos, acceso inusual a recursos compartidos).
- Dashboards de seguridad con indicadores de compromiso (IoC) actualizados.

B. EDR (Endpoint Detection and Response)

Los EDR monitorizan el comportamiento de los procesos en cada endpoint. Ante un proceso que comienza a cifrar archivos masivamente, el EDR puede bloquearlo automaticamente y aislar el equipo de la red. Ejemplos: CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint.

C. IDS/IPS (Intrusion Detection/Prevention System)

Monitoriza el trafico de red en busca de patrones de ataque conocidos y comunicaciones con servidores de comando y control (C2). La deteccion de comunicaciones C2 en fases tempranas del ransomware habria podido interrumpir el ataque.

D. Monitoreo de Comportamiento de Usuarios y Entidades (UEBA)

- Detectar accesos inusuales a recursos de red (horas no habituales, volumenes anormales de lectura/escritura).
- Identificar cuentas comprometidas que acceden a sistemas fuera de su perfil habitual.
- Alertas ante escalada de privilegios no autorizada.

3.2 Protocolo de Alerta Temprana

Un protocolo de alerta temprana estructurado en niveles de severidad habria permitido a TechCo contener el ataque en sus fases iniciales:

Nivel de Alerta	Criterios y Acciones
NIVEL 1 - Informacion	Actividad inusual detectada (ej: fallo de autenticacion multiple). Notificacion automatica al equipo de seguridad. Investigacion preventiva en 4 horas.
NIVEL 2 - Advertencia	Patron de comportamiento anomalo confirmado (ej: proceso intentando acceder a multiples archivos). Alerta inmediata al SOC. Analisis en 1 hora. Consideracion de aislamiento.
NIVEL 3 - Critico	Indicadores de compromiso activo (IoC) confirmados (ej: cifrado de archivos en curso, comunicacion C2). Activacion inmediata del Plan de Respuesta a Incidentes. Aislamiento del segmento afectado.
NIVEL 4 - Emergencia	Incidente de seguridad mayor en curso con impacto en produccion. Activacion del Equipo de Respuesta a Incidentes completo. Notificacion a la gerencia y escalada a autoridades si aplica.

3.3 Indicadores de Compromiso (IoC) de Ransomware

Los siguientes IoC deben configurarse como reglas de deteccion en el SIEM y EDR:

- Cifrado masivo y rapido de archivos (cambio de extension, alta tasa de escritura en disco).
- Eliminacion de shadow copies del sistema operativo (vssadmin delete shadows).
- Comunicaciones de red hacia IPs o dominios desconocidos o con reputacion maliciosa.
- Creacion de archivos README o similares con instrucciones de rescate.
- Deshabilitacion de herramientas de seguridad (antivirus, EDR) mediante comandos del sistema.
- Movimiento lateral via protocolos como SMB, RDP, PsExec entre segmentos de red.

04

RESPONDER

Funcion 4 del Marco NIST CSF 2.0 — Plan de Respuesta al Incidente

4.1 Equipo de Respuesta a Incidentes (CSIRT)

Rol	Responsabilidades
Director de Respuesta (CISO / IT Manager)	Liderar la respuesta, tomar decisiones criticas, coordinar con la gerencia y autoridades externas.
Analistas de Seguridad (x2)	Investigacion forense, analisis de malware, contencion tecnica del incidente.
Administrador de Sistemas	Aislamiento de sistemas, gestion de infraestructura, restauracion desde backups.
Responsable Legal / Compliance	Evaluar obligaciones regulatorias, coordinar notificacion a autoridades y clientes afectados.
Responsable de Comunicaciones	Gestionar comunicacion interna y externa, preparar comunicados oficiales.
Proveedor de IR Externo (si aplica)	Soporte especializado en respuesta a incidentes, analisis forense avanzado y negociacion.

4.2 Fases del Plan de Respuesta

FASE 1: Contencion Inmediata (0-2 horas)

1. Activar el Plan de Respuesta a Incidentes y notificar al CSIRT completo.
2. Aislar inmediatamente los sistemas afectados desconectandolos de la red (desactivar interfaces de red, no apagar los equipos para preservar evidencia en memoria RAM).
3. Identificar el alcance de la propagacion: que sistemas estan cifrados, que segmentos de red fueron alcanzados.
4. Bloquear el acceso a Internet del segmento afectado para interrumpir comunicaciones con el servidor C2.
5. Preservar logs y evidencia digital (snapshots de memoria, copias forenses de discos) antes de cualquier accion de remediacion.

FASE 2: Evaluacion y Analisis (2-8 horas)

1. Identificar la variante de ransomware utilizando herramientas como ID Ransomware (nomoreransom.org).
2. Determinar el vector de entrada inicial (equipo del empleado afectado).
3. Evaluar que datos fueron exfiltrados (ademas del cifrado, muchos ransomware modernos extraen datos).
4. Verificar la integridad de todos los backups disponibles (internos, externos, en nube).
5. Consultar con el equipo legal sobre obligaciones de notificacion regulatoria (GDPR, Ley de Proteccion de Datos local).

FASE 3: Eradicacion (8-48 horas)

1. Remover el malware de todos los sistemas afectados mediante formateo y reinstalacion (no confiar en herramientas de limpieza para ransomware avanzado).
2. Identificar y parchear la vulnerabilidad explotada para el acceso inicial.
3. Revocar y resetear todas las credenciales de acceso de sistemas comprometidos.
4. Revisar y endurecer las politicas de seguridad en endpoints, correo y red.

4.3 Comunicacion Durante el Incidente

Tipo de Comunicacion	Lineamientos y Protocolos
Comunicacion Interna	Notificacion inmediata a la gerencia (CEO, CFO, CTO). Canal seguro de comunicacion fuera de la red comprometida (Signal, telefono). Actualizaciones de estado cada 2 horas al equipo directivo. Instrucciones claras a empleados: no encender equipos apagados, no acceder a sistemas, reportar cualquier anomalia.
Comunicacion Externa	Notificar a clientes afectados dentro del plazo legal (72 horas segun GDPR si aplica). Preparar comunicado oficial que no revele detalles tecnicos sensibles. Contactar a las fuerzas de seguridad (CSIRT nacional, FBI IC3 si aplica). NO hacer declaraciones publicas durante la fase activa del incidente. Coordinar con asesores legales y de PR toda comunicacion publica.

Politica sobre el Pago del Rescate

Recomendacion: NO pagar el rescate. El pago no garantiza la recuperacion de los datos, puede financiar actividades criminales, y puede hacer a TechCo un objetivo recurrente. Ademias, en algunas jurisdicciones el pago a grupos sancionados puede tener implicaciones legales. La decision final debe tomarse con asesoria legal especializada y considerando si existen backups recuperables.

05

RECUPERAR

Funcion 5 del Marco NIST CSF 2.0 — Restauracion y Continuidad del Negocio

5.1 Plan de Recuperacion de Sistemas

A. Orden de Prioridad de Restauracion

La restauracion debe seguir un orden basado en criticidad para el negocio:

1. Infraestructura de identidad y accesos (Active Directory, servicios de autentificacion).
2. Sistemas de comunicacion criticos (correo corporativo en nube segura, telefonia).
3. Base de datos de clientes (previa verificacion forense de integridad).
4. Sistemas de produccion de servicios en la nube (core business de TechCo).
5. Servidor de archivos y documentacion operativa.
6. Sistemas administrativos y de soporte.

B. Proceso de Restauracion

- Utilizar unicamente backups verificados como no comprometidos (preferentemente el backup offsite o inmutable).
- Restaurar en entornos de red previamente saneados y con segmentacion implementada.
- Verificar la integridad de cada sistema restaurado antes de reconectarlo a la red de produccion.
- Implementar monitoreo intensivo (EDR + SIEM) en todos los sistemas restaurados durante al menos 30 dias post-incidente.
- No restaurar sistemas hasta que el vector de ataque inicial haya sido completamente remediado.

5.2 Plan de Continuidad del Negocio (BCP)

Durante el periodo de recuperacion (que puede extenderse de dias a semanas), TechCo debe activar las siguientes medidas de continuidad:

Area	Acciones de Continuidad
Comunicacion de Emergencia	Activar canales de comunicacion alternativos (cuentas de correo externas temporales, telefonía móvil). Establecer sala de guerra (war room) con comunicacion fuera de la red comprometida.
Operaciones Minimas	Identificar procesos criticos que pueden operar manualmente o con sistemas alternativos. Activar acuerdos con proveedores alternativos para servicios criticos.
Atencion a Clientes	Comunicar proactivamente el estado del incidente y el plan de recuperacion a clientes. Activar mesa de ayuda de emergencia para consultas de clientes afectados.
Soporte Legal y Regulatorio	Iniciar proceso de notificacion a autoridades de proteccion de datos. Documentar todas las acciones tomadas para cumplimiento normativo y seguros ciberneticos.
Gestión Financiera	Activar póliza de seguro de ciberriesgo si existe. Reservar presupuesto de emergencia para contratar servicios de IR externo y herramientas adicionales.

5.3 Criterios de Fin del Incidente y Retorno a la Normalidad

- Todos los sistemas criticos han sido restaurados desde backups verificados.
- El malware ha sido completamente erradicado y no se detectan IoC activos.
- Las vulnerabilidades que facilitaron el ataque han sido remediadas.
- Los controles de seguridad mejorados (EDR, SIEM, segmentacion, MFA) estan operativos.
- La notificacion a clientes y autoridades ha sido completada segun plazos legales.
- El informe post-incidente ha sido elaborado y aprobado por la gerencia.

06

MEJORA CONTINUA

Leccion Aprendida y Evolucion del Plan de Seguridad

6.1 Evaluacion Post-Incidente (Post-Mortem)

Dentro de los 14 dias posteriores al cierre del incidente, el CSIRT debera realizar una reunion de post-mortem estructurada con el siguiente enfoque:

Dimension del Analisis	Metodologia y Objetivos
Timeline del Incidente	Reconstruir la cronologia completa: desde el primer email de phishing hasta la deteccion y contencion. Identificar cada punto de fallo y cada oportunidad de intervencion perdida.
Analisis de Causa Raiz	Aplicar la metodologia '5 Por Que' para cada vulnerabilidad identificada. Distinguir causas tecnicas, de proceso y humanas.
Efectividad de la Respuesta	Evaluar los tiempos de deteccion, contencion y recuperacion contra los objetivos del plan. Identificar cuellos de botella en la respuesta.
Gaps de Cobertura	Identificar controles de seguridad ausentes o ineficaces. Priorizar mejoras segun impacto y coste de implementacion.

6.2 Metricas de Eficacia del Plan

TechCo debe implementar y monitorizar las siguientes metricas de seguridad de forma continua:

- MTTD (Mean Time to Detect): tiempo promedio desde que un incidente comienza hasta que es detectado. Objetivo: menos de 1 hora para incidentes criticos.
- MTTR (Mean Time to Respond): tiempo desde la deteccion hasta la contencion activa. Objetivo: menos de 4 horas.
- MTTRC (Mean Time to Recover): tiempo hasta la restauracion completa de operaciones. Objetivo: menos de 72 horas para incidentes mayores.
- Tasa de clics en simulaciones de phishing: objetivo reducir a menos del 5% en 12 meses.
- Cobertura de parches criticos: 100% de endpoints con parches criticos aplicados en menos de 48 horas.
- Porcentaje de sistemas con MFA habilitado: objetivo 100%.

6.3 Ciclo de Mejora Continua

El Plan de Respuesta a Incidentes debe evolucionar continuamente mediante el siguiente ciclo:

1. Revision anual completa del plan con actualizacion de amenazas del panorama actual.
2. Ejercicios de simulacion (tabletop exercises) semestrales con el CSIRT y la gerencia.
3. Red Team / Penetration Testing anual para identificar nuevas vulnerabilidades.
4. Actualizacion de playbooks especificos por tipo de incidente (ransomware, DDoS, fuga de datos).
5. Revision de controles de seguridad tras cada incidente o cuasi-incidente reportado.
6. Benchmarking contra frameworks actualizados (NIST CSF, ISO 27001, CIS Controls).

6.4 Hoja de Ruta de Mejoras Prioritarias

Horizonte Temporal	Acciones Clave
Inmediato (0-30 dias)	Implementar EDR en todos los endpoints. Configurar backups offsite e inmutables. Activar MFA en todos los sistemas criticos. Establecer segmentacion basica de red.
Corto plazo (30-90 dias)	Desplegar solucion SIEM con reglas de deteccion de ransomware. Implementar filtros avanzados de correo con sandbox de adjuntos. Iniciar programa de capacitacion en phishing. Contratar proveedor de IR externo bajo contrato de retainer.
Mediano plazo (90-180 dias)	Implementar arquitectura Zero Trust completa. Desarrollar y probar el BCP y DRP formales. Obtener certificacion ISO 27001 o equivalente. Contratar seguro de ciberriesgo.
Largo plazo (180+ dias)	Establecer SOC (Security Operations Center) interno o bajo servicio gestionado (MSSP). Programa maduro de gestion de vulnerabilidades. Evaluaciones periodicas de Red Team. Mejora continua basada en metricas y benchmarking.

Conclusion

El ataque de ransomware sufrido por TechCo es un recordatorio de que la ciberseguridad no es un estado a alcanzar, sino un proceso continuo de mejora. Las vulnerabilidades identificadas en este caso, que van desde la falta de segmentacion de red hasta la ausencia de monitoreo en tiempo real, son problemas comunes pero prevenibles.

La implementacion del Marco NIST CSF como estructura organizadora del plan de respuesta proporciona a TechCo un lenguaje comun, objetivos medibles y una hoja de ruta clara para transformar su postura de seguridad de reactiva a proactiva.

El exito de este plan dependera de tres factores criticos: el compromiso de la alta gerencia con la inversion en ciberseguridad, la capacitacion continua de todo el personal, y la disciplina organizacional para mantener y probar los controles implementados.

Principio Fundamental

La pregunta no es si una organizacion sufrira un ciberataque, sino CUANDO. La diferencia entre una empresa que sobrevive a un ataque y una que no lo hace reside en la preparacion previa, la velocidad de respuesta y la capacidad de recuperacion. Este plan es el primer paso para que TechCo se ubique en el primer grupo.

Informe preparado conforme al NIST Cybersecurity Framework (CSF) 2.0

Clasificacion: CONFIDENCIAL | TechCo | Junio 2026

Diego Dario Silva Amorin | 4GeeksAcademy